

VAPT CAPSTONE SECURITY ASSESSMENT

Comprehensive Penetration Testing & Vulnerability Assessment Report

Assessment Type: Controlled Security-Lab Capstone

Frameworks: CVSS 3.1 and OWASP

Audience: Executive Committee, Developers, Sysadmins

This report must not be represented as a real-world assessment without genuine authorized evidence.

1. Document Control

Field	Value
Document	VAPT Capstone Security Assessment
Version	1.0
Assessment	Controlled security-lab capstone
Rating	CVSS 3.1
Taxonomy	OWASP
Audience	Executive security review
Status	Mentor review

Assessment Statement

This document provides a structured VAPT report and remediation plan. Technical findings are controlled-lab examples, not claims that a named production system was compromised.

Evidence Handling

Public copies should contain only synthetic data and sanitized evidence. Do not commit credentials, private keys, personal data, or production logs.

2. Executive Summary

This capstone presents a controlled VAPT assessment framework for executive review. It focuses on common application and configuration weaknesses that can affect confidentiality, integrity, and availability.

Finding	Severity	CVSS	Concern
VAPT-04	Critical	9.1	Injection
VAPT-03	High	8.1	Object authorization
VAPT-02	High	7.5	Authentication
VAPT-05	Medium	6.5	Logging/configuration
VAPT-01	Medium	5.3	Security headers

The risk order is a remediation-planning structure based on technical severity bands, not a claim about exploitability on an untested system.

3. Scope and Rules of Engagement

The assessment covers application-layer controls, authentication, authorization, input handling, configuration, logging, and security headers in an authorized laboratory.

Area	Restriction
Third-party systems	No testing without explicit authorization
Production data	Excluded
Denial of service	Excluded
Destructive exploitation	Excluded
Credential theft	Excluded

Use approved targets, minimize impact, maintain an evidence trail, stop if unexpected sensitive information appears, and escalate critical issues through the agreed process.

4. Testing Methodology

The lifecycle is: authorization and scoping; reconnaissance; vulnerability identification; safe validation; risk analysis; reporting; remediation; and retesting.

Area	Example checks
Authentication	Password policy, sessions, throttling
Authorization	Roles and object ownership
Input validation	Injection and unsafe parsing
Configuration	Headers and information disclosure
Logging	Sensitive data and security events
Dependencies	Known vulnerable/unsupported components

Server-side controls receive particular attention because client-side restrictions can be bypassed.

5. Risk Rating and CVSS 3.1

CVSS 3.1 communicates technical severity. Business risk also depends on asset criticality, exposure, compensating controls, and regulatory impact.

Score	Severity
0.0	None
0.1–3.9	Low
4.0–6.9	Medium
7.0–8.9	High
9.0–10.0	Critical

Critical and high findings should enter expedited remediation workflows according to organizational risk appetite.

6. OWASP Mapping

Finding	OWASP	Theme
VAPT-01	A05 Security Misconfiguration	Configuration
VAPT-02	A07 Identification and Authentication Failures	Authentication
VAPT-03	A01 Broken Access Control	Authorization
VAPT-04	A03 Injection	Input handling
VAPT-05	A09 / A05	Logging and configuration

OWASP mapping supplies a common application-security vocabulary; evidence is still required to prove a vulnerability.

7.1 Technical Finding — VAPT-01

Missing or Weak Security Headers

Severity	Medium
CVSS 3.1	5.3
OWASP	A05 Security Misconfiguration

Description: Representative application responses may lack a consistent browser-security header baseline.

Security Impact: Browser-side attack exposure can increase when defense-in-depth headers are missing.

Evidence: Review representative HTTP responses in the authorized lab and save sanitized evidence.

Remediation: Define and centrally deploy a header baseline. Test compatibility and enable HSTS only with correct HTTPS deployment.

Retest: Inspect responses after deployment and run application regression tests.

Assessment note: this is a controlled-lab finding model. Replace this guidance with genuine authorized evidence before calling it a verified production finding.

7.2 Technical Finding — VAPT-02

Weak Authentication / Password Policy

Severity	High
CVSS 3.1	7.5
OWASP	A07 Identification and Authentication Failures

Description: Assess password policy, login throttling, sessions, and account recovery in the lab.

Security Impact: Weak controls can increase the chance of account compromise.

Evidence: Use synthetic accounts and sanitized authentication results.

Remediation: Use adaptive password hashing, rate limiting, secure sessions, MFA where appropriate, and secure recovery.

Retest: Retest valid/invalid login, repeated failures, sessions, logout, and recovery.

Assessment note: this is a controlled-lab finding model. Replace this guidance with genuine authorized evidence before calling it a verified production finding.

7.3 Technical Finding — VAPT-03

Broken Object-Level Authorization Risk

Severity	High
CVSS 3.1	8.1
OWASP	A01 Broken Access Control

Description: Every object access must be authorized server-side; client-supplied identifiers are not proof of ownership.

Security Impact: Successful abuse could expose or modify another user's records.

Evidence: Use two synthetic accounts and compare authorized and unauthorized object requests.

Remediation: Enforce ownership/role checks at the server/API layer for every object access.

Retest: Repeat cross-user tests with multiple roles and identifiers.

Assessment note: this is a controlled-lab finding model. Replace this guidance with genuine authorized evidence before calling it a verified production finding.

7.4 Technical Finding — VAPT-04

Injection Risk from Unsafe Input Handling

Severity	Critical
CVSS 3.1	9.1
OWASP	A03 Injection

Description: Input reaching a database or interpreter without safe parameterization can create injection risk.

Security Impact: Impact may include unauthorized data access or command execution depending on the interpreter and privileges.

Evidence: Use harmless, non-destructive inputs in an isolated lab and preserve sanitized request/response evidence.

Remediation: Use parameterized APIs, allow-list validation where appropriate, least privilege, and regression tests.

Retest: Repeat the original safe test and verify malicious syntax is treated as data.

Assessment note: this is a controlled-lab finding model. Replace this guidance with genuine authorized evidence before calling it a verified production finding.

7.5 Technical Finding — VAPT-05

Sensitive Information Exposure through Logging / Configuration

Severity	Medium
CVSS 3.1	6.5
OWASP	A09 / A05

Description: Logs and configuration can unintentionally contain credentials, tokens, personal data, or excessive diagnostics.

Security Impact: Exposure can enable follow-on compromise and create privacy/compliance risk.

Evidence: Review synthetic logs/configuration and redact values in evidence.

Remediation: Remove secrets from logs, restrict log access, centralize security events, rotate exposed credentials.

Retest: Verify representative events contain required context without sensitive secret values.

Assessment note: this is a controlled-lab finding model. Replace this guidance with genuine authorized evidence before calling it a verified production finding.

12. Prioritized Remediation Plan

Priority	Finding	Timeline	Owner
P1	VAPT-04	0–7 days	Development + DBA/Platform
P1	VAPT-03	0–7 days	Application Engineering
P2	VAPT-02	8–30 days	Application + IAM
P2	VAPT-01	8–30 days	Platform / DevOps
P2	VAPT-05	8–30 days	DevOps / Security

Timelines are recommended capstone targets; actual deadlines should follow organizational risk appetite and change management.

13. Developer Patch Guidelines

1. Parameterize inputs reaching interpreters.
2. Enforce authorization at the server/API layer.
3. Use adaptive password hashing and secure authentication libraries.
4. Add negative tests for unauthorized access and malicious input.
5. Centralize security-header configuration.
6. Load secrets from approved secret-management mechanisms.
7. Prevent sensitive values from entering logs.
8. Add security regression tests to CI.

14. Sysadmin / Infrastructure Hardening

1. Enforce HTTPS and secure transport.
2. Restrict database and management interfaces.
3. Use least-privilege service accounts.
4. Patch supported operating systems and dependencies.
5. Centralize and protect security logs.
6. Alert on repeated authentication failures and authorization anomalies.
7. Back up critical systems and test restoration.
8. Rotate credentials and keys after suspected exposure.
9. Maintain an inventory of internet-facing assets.

15. Retesting and Verification

Stage	Verification
Original case	Reproduce documented issue
Patch	Deploy remediation
Regression	Confirm legitimate functionality
Negative test	Confirm abuse case fails
Bypass test	Check alternate paths
Evidence	Capture sanitized proof
Closure	Record owner/date/status

A finding is not closed merely because code changed. The original test and regression/bypass checks must be documented.

16. Security Governance and Monitoring

A sustainable program combines secure development, vulnerability management, identity controls, infrastructure hardening, monitoring, and periodic testing.

Metric	Purpose
Critical findings past SLA	Urgent remediation backlog
Mean time to remediate	Response speed
Recurring findings	Systemic control gaps
Retest pass rate	Remediation effectiveness
Secrets detected	Secret-management hygiene
Authentication alerts	Detection capability

17. Executive Conclusion

This capstone demonstrates how VAPT observations can be translated into executive risk information and actionable remediation.

The central operational principles are server-side security enforcement, protection of credentials and secrets, minimized exposure, and verification through repeatable retesting.

Final status: suitable for mentor review as a controlled security-lab capstone. Attach genuine authorized evidence before presenting any finding as a real-world result.

18. Evidence and Finding Record

Field	Record
Finding ID	VAPT-XX
Target	Authorized lab identifier
Tester	Name / team
Date/time	YYYY-MM-DD HH:MM
Test case	Reproducible description
Tool/version	If applicable
Evidence	Screenshot/log reference
CVSS	Score + vector
OWASP	Category
Remediation	Fix reference
Retest	Pass/fail + evidence

Sanitize evidence before publishing it.

19. Submission Checklist

Item	Status
Executive-ready VAPT report	Prepared
15–20 page PDF	Prepared
Executive summary	Included
CVSS 3.1 matrix	Included
OWASP mapping	Included
Technical findings	Included
Remediation timelines	Included
Developer guidelines	Included
Sysadmin guidelines	Included
Retesting procedure	Included
GitHub repository structure	Prepared
Evidence checklist	Included

20. Appendix — Safe Testing Statement

This capstone is designed for authorized, isolated security testing. No real production system should be scanned, exploited, or stress-tested without explicit permission.

When genuine authorized evidence is available, replace the controlled-lab placeholders with the actual target identifier, timestamps, sanitized screenshots, request/response evidence, CVSS vector, remediation reference, and retest result.

Public GitHub copies should remain free of credentials, personal data, private keys, and sensitive infrastructure information.